

Risk Management Plan: SmartShift Planner

Test intent

- Path: happy path
- Intended workflow outcome: the app should treat this as a product-specific risk management plan with strong governance and reviewable controls.

1. Purpose and Scope of Risk Management Activities

This plan defines the product-specific risk management activities for SmartShift Planner across design, development, verification, release, operation, and post-release monitoring.

Scope includes:

- software failure, cybersecurity, privacy, and AI/ML risks
- supplier and integration risks for identity and Microsoft Graph calendar sync
- production and post-production feedback relevant to harm prevention and compliance

2. Product Description

SmartShift Planner is a multi-tenant web application that creates and publishes work schedules. It uses AI-assisted ranking to propose schedules and a human approval step before publishing to employee calendars.

3. Responsibilities and Authorities

- Risk Manager: maintains the risk file and chairs formal reviews.
- Engineering Lead: ensures technical mitigations are implemented and verified.
- Security Engineer: owns threat modeling, vulnerability treatment, and hardening evidence.
- Privacy Officer: confirms lawful processing, minimization, retention, and breach readiness.
- Product Owner: confirms acceptable residual business risk and intended use alignment.
- Quality Manager: verifies completeness of evidence and CAPA closure.

Authority to block release is explicitly granted to the Risk Manager, Security Engineer, and Privacy Officer when unacceptable residual risk remains.

4. Methods and Procedures

- preliminary hazard analysis for major workflow changes
- FMEA for component and process-level failure analysis
- misuse and abuse case analysis for adversarial and insider scenarios
- security threat modeling for interfaces, secrets, identity, and tenant boundaries
- privacy impact checks for new data uses and exports

5. Risk Acceptance Criteria

- No untreated critical security or privacy risk may be accepted for release.

- High-severity risks require documented mitigation, verification, and named residual risk ownership.
- Residual risk acceptance must be reviewed by cross-functional stakeholders and linked to evidence.
- Benefit-risk rationale must be documented for any exceptional acceptance decision.

6. Verification of Risk Control Measures

- test evidence for security, privacy, functional, and resilience controls
- confirmation that human oversight, rollback, and monitoring are effective
- verification records stored with the release evidence package

7. Production and Post-Production Activities

- monitor incidents, override rates, complaints, and unusual calendar sync behavior
- reassess risks after significant model, data, architecture, or supplier changes
- trigger CAPA for repeated control failure or audit nonconformance

8. Tools and Records

- governed risk register
- controlled FMEA workbook
- issue tracker with remediation linkage
- test evidence repository
- security scanning and structured logging tooling

9. Review and Approval Cadence

- monthly operational risk review
- release-based formal risk review
- immediate review after high-severity incident, major change, or regulatory trigger

10. Expected Review Outcome

Expected app/user result:

- suitable for approval or controlled in-review workflow
- should support low residual findings focused on future improvements rather than missing fundamentals